kompass-isms

AWS 계정을 읽기 전용으로 점검해 KISA 클라우드 취약점 점검 가이드·ISMS-P 기준의 점검표를 만들고, LLM이 원문 근거 해설과 증적 문서 검토를, 에이전트가 읽기 전용 추가 조사를 맡는 보안 진단 도구. 판정은 결정론적 룰이 내리고, LLM 출력은 원문·도구 호출 기록·문서 발췌와 코드로 대조해 검증하며, 품질은 평가셋으로 수치화함.

요약

KISA 항목 (19개): 취약 15, 확인 불가 0, 검토 필요 3, 양호 1, 해당 없음 0, 점검하지 않음 0, 수동 점검 (미구현) 0

finding: 취약 40, 확인 불가 0, 검토 필요 18, 양호 65, 해당 없음 3

KISA 항목별 결과

2026 주요정보통신기반시설 기술적 취약점 분석·평가 방법 상세가이드 XII. 클라우드 기준. partial 항목은 자동 점검만으로 양호가 되지 않음.

코드	항목	중요도	분류	결과	룰	finding
CA-01	사용자 계정 관리	상	partial	검토 필요	IAM-005	PASS 3
CA-02	사용자 정책 관리	중	partial	취약	IAM-002, IAM-007, IAM-008	FAIL 2, PASS 1, REVIEW 4
CA-03	MFA(Multi-Factor Authentication) 설정	상	full	취약	IAM-001, IAM-003, IAM-009	FAIL 1, PASS 1, REVIEW 1
CA-04	클라우드 계정 비밀번호 정책 관리	중	partial	취약	IAM-004	FAIL 1
CA-05	인스턴스 서비스 정책 관리	상	partial	검토 필요	IAM-010	REVIEW 6
CA-06	네트워크 서비스 정책 관리	상	partial	검토 필요	IAM-011	REVIEW 5
CA-07	VPC 네트워크 서브넷 관리	상	partial	취약	VPC-001	FAIL 1, N/A 1, PASS 1
CA-08	가상 네트워크 리소스 관리	중	partial	취약	VPC-002, RDS-002	FAIL 1, PASS 1, REVIEW 2
CA-09	접근 제어 설정 관리	상	partial	취약	SG-001, SG-002, SG-003	FAIL 5, PASS 25
CA-10	스토리지 리소스 퍼블릭 접근 관리	중	partial	취약	RDS-006, S3-001, S3-002, S3-003, S3-006	FAIL 8, PASS 10
CA-11	관계형 데이터베이스 암호화 설정	중	partial	취약	RDS-001	FAIL 1, PASS 1
CA-12	통신구간 암호화 설정	중	partial	취약	RDS-005, ELB-001, ELB-002, S3-007	FAIL 7, PASS 4
CA-13	클라우드 서비스 사용자 계정 로깅 설정	상	full	양호	CT-001	PASS 1
CA-14	인스턴스 로깅 설정	중	partial	취약	VPC-003	FAIL 1, N/A 1, PASS 1
CA-15	관계형 데이터베이스 로깅 설정	중	partial	취약	RDS-003	FAIL 1, PASS 1
CA-16	오브젝트 스토리지 버킷 로깅 설정	중	full	취약	S3-005	FAIL 4, PASS 1
CA-17	로그 보관 기간 설정	중	partial	취약	CT-002, LOG-001	FAIL 3, PASS 1
CA-18	백업 사용 여부	중	partial	취약	RDS-004, BKP-001, BKP-002, BKP-003	FAIL 2, PASS 4
CA-19	가상 리소스 이상징후 알림 설정	중	partial	취약	GD-001, GD-002	FAIL 1, N/A 1

실습 계정 점검 보고서의 KISA 클라우드 19개 항목 결과

핵심 수치

항목	값
LLM 해설 평가	77개 케이스, 실제 모델 154회 시도(약 $10). 기준선 40개 × 2회에서 인용 검증 통과 100%, 조치 작업 일치 99.4%
증적 문서 검토 평가	8개 케이스(프롬프트 주입·개인정보 포함). 9개 지표 모두 100%, 8개 1회 실행 약 $0.34
에이전트 추가 조사	실습 계정 32개 룰의 조사 결과 근거 검증 32/32, 읽기 전용 도구 호출 190회, 약 $5.77
점검 범위	AWS 9개 서비스 41개 룰
검증	테스트 1,181개, 실습 AWS 계정 기대값 121건(선택 리소스 조합별) 대조
개발	2026.10 (약 2주), 커밋 130여 개, 설계 결정 기록(ADR) 54건

- **케이스**: 룰 하나의 해설 요청을 재현한 시험 문제. 실습 결과 가공 31개, 실습에 없는 상황(권한 오류 등) 46개.
- **시도**: 답이 매번 달라질 수 있어 케이스마다 2회 실행(77 × 2). **기준선**은 처음 한꺼번에 실행한 40개로, 이후 변경의 비교 기준.
- **인용 검증**: 인용한 항목 코드·문장이 매핑과 원문에 실제로 있는지 대조. 100%는 지어낸 인용이 없었다는 뜻.
- **조치 작업 일치**: CLI 명령에 문제를 고치는 API 작업(예: `s3:PutPublicAccessBlock`)이 있는지 대조. 80회 중 1회에서 일부 누락.
- **근거 검증**: 에이전트의 사실마다 단 근거 도구 호출이 실제로 실행된 호출인지 대조.

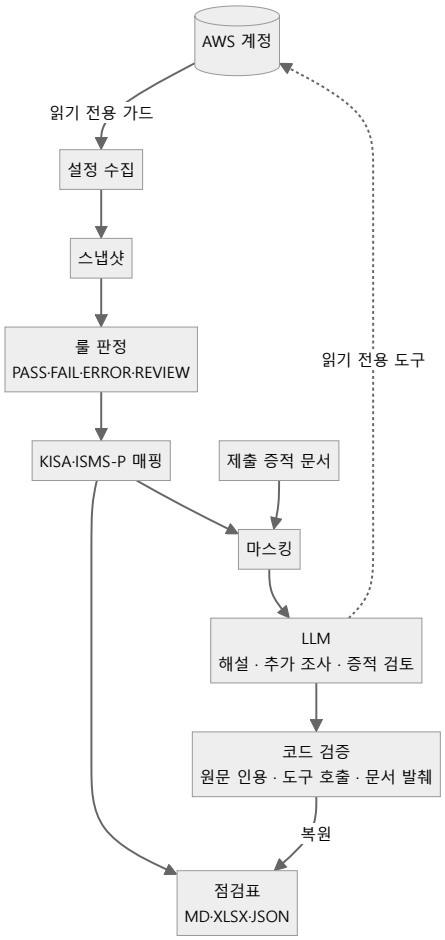
기준	전체	자동 점검	양호까지 자동 판정	사람 확인 병행
KISA 클라우드 점검 항목	19	19 (100%)	3 (16%)	16 (84%)
ISMS-P 통제항목	101	15 (15%)	0	15 (기술 증적만 제공)

- **KISA**: 16개 항목은 기준에 설정으로 확인할 수 없는 조건(주기적 검토, 업무상 필요성 등)이 있어, 룰이 모두 양호여도 "검토 필요"로 집계함. 일부만 확인하고 양호라고 보고하지 않기 위함이며, 명백한 위반은 19개 항목 모두 자동으로 취약 판정함.
- **ISMS-P**: 정책·절차·기록까지 요구하는 관리체계 기준이라 설정만으로 충족을 판단할 수 없음. 15개 통제에 기술 증적만 제공함.
- 자동화 밖의 항목은 증적 요청서와 LLM 문서 검토로 사람의 판단을 도움.

문제와 접근

- **문제**: 클라우드 ISMS-P·KISA 점검은 설정 수집 뒤에도 점검표 작성, 기준 원문 인용, 조치안 작성, 담당자 증적 요청·검토가 대부분 수작업임.
- **LLM만으로 판정할 때의 한계**: 같은 입력에도 결과가 달라지고, 기준 조항이나 리소스를 지어낼 수 있으며, 판정 근거를 감사인에게 설명하기 어려움.
- **접근**: 판정은 재현 가능한 코드가, 판정 이후의 해석·조사·문서 검토는 LLM이 맡음. LLM의 모든 주장에는 코드로 대조할 수 있는 근거를 요구함.

아키텍처



- **결정론 계층**: 수집과 판정을 분리해 스냅샷만으로 재판정·재현 가능함. 판정 결과는 이후 변경되지 않음.
- **LLM 계층**: 확정된 판정 결과를 마스킹해 읽기만 하며, 출력은 검증 결과와 함께 보고서의 "참고" 절에 붙음(검증 실패는 "검증되지 않음"으로 표시).

LLM 활용 지점

기능 (명령)	LLM이 하는 일	목적	출력 검증
룰별 해설 (`explain`)	원문 인용, 위험 설명, 우선순위, 조치 방안(AWS CLI·Terraform) 작성	근거 인용·조치안 작성 시간 단축	인용 코드·구절을 원문과 대조
종합 위험 평가 (`explain`)	여러 결과가 겹쳐 생기는 위험 시나리오와 조치 순서 작성	복합 위험과 조치 우선순위 파악	시나리오의 finding·조치 순서를 실제 결과와 대조
에이전트 추가 조사 (`investigate`)	읽기 전용 도구로 정책·변경 이력·권한 시뮬레이션 등을 스스로 추가 조회	콘솔 확인 작업을 대신해 판단 근거 보강	사실마다 근거 도구 호출 ID를 호출 기록과 대조
증적 문서 검토 (`review-evidence`)	제출 문서에서 확인된 사실·부족한 점·추가 요청 정리	자동 점검이 불가능한 항목의 검토 시간 단축	사실마다 문서 발췌가 실제 문서에 있는지 대조
MCP 서버 (`mcp`)	Claude Code 등 외부 LLM 클라이언트가 판정 결과·조사 도구 호출	대화형 결과 탐색·조사	같은 마스킹·읽기 전용 가드·호출 상한

설정 수집, 판정, 매핑, 점검표, 증적 요청서에는 LLM을 쓰지 않음. 모든 LLM 단계는 선택 실행이며 판정을 바꾸지 않음.

AI 설계의 핵심

1. **판정과 해석의 분리**: 취약·양호 판정은 코드가 내리고 LLM은 설명만 함. LLM 응답 양식에 판정 칸이 없고 판정 결과는 수정할 수 없게 저장되어, LLM이 판정을 바꿀 방법 자체가 없음. 이를 테스트로 확인함.
2. **식별정보 마스킹**: 계정 ID·ARN·IP·리소스 이름을 종류를 남긴 자리표시자(`MASKED_SG_1`)로 바꿔 보내고 응답을 로컬에서 복원함. 전송 직전에 원본 값이 남아 있으면 보내지 않음(fail closed).
3. **원문 인용 검증**: KISA·ISMS-P 원문을 항목 코드 단위로 색인해 매핑된 코드로 꺼내 넣음. 인용이 원문에 없으면 한 번 다시 요청하고, 그래도 틀리면 "검증되지 않음"으로 표시함. 항목 코드가 이미 정해져 있어 벡터 검색은 쓰지 않음.
4. **에이전트 도구 설계**: 범용 API 호출 대신 응답 형태가 정해진 읽기 전용 도구 12개만 제공해 처음 보는 식별자도 필드 단위로 마스킹함. 호출 수·반복·토큰 예산과 조사 로그를 둠.
5. **신뢰할 수 없는 입력**: 제출 증적 문서 속 지시는 따르지 않도록 하고(평가셋에 프롬프트 주입 케이스 포함), 개인정보는 패턴·이름 사전으로 가린 뒤 전송 전 미리보기로 사람이 확인함.

LLM 품질 평가

LLM 판정자 없이 코드 채점기로만 평가해, 같은 응답은 언제 채점해도 결과가 같고 기록한 응답으로 비용 없이 다시 채점할 수 있음.

- **평가셋**: 실습 계정 결과를 가짜 식별자로 가공한 케이스에, 실습에서 나오지 않는 상황(권한 오류, 검토 필요, 상태 혼합)을 다루는 보강 케이스를 더함. 증적 검토 케이스는 프롬프트 주입·개인정보를 담은 가공 문서로 작성함.
- **지표**: 인용 검증·정밀도, 핵심 근거 인용, CLI 명령 유효성(AWS 공식 API 명세와 대조), 조치 작업·대상 리소스 일치, 식별정보 노출, 자리표시자 지어냄, 문체.
- **채점기 검증**: 실제 모델을 돌리기 전에 모범 답안은 만점, 빈 답안은 0점이 나오는지 먼저 확인해 채점기 자체의 오류를 걸러 냄. 채점기를 고치면 기존 결과를 다시 채점해 점수가 그대로인지 확인함.
- **평가가 찾은 결함**: 자리표시자 번호 10 이상에서 요청을 모두 막던 마스킹 버그, 조치 명령에 필요한 백업 계획 ID가 증적에 없던 문제 등. 증적 검토는 프롬프트를 고쳐 과잉 지적을 6건에서 0건으로 줄임.
- **한계**: 지표가 대부분 만점이라 지금은 회귀 검출용임. 개선 측정에는 더 어려운 케이스나 LLM 판정자 지표가 필요함.

해설 평가 결과 — baseline

채점된 시도 80건 (케이스 40개), 채점 못한 실패 0건

지표	평균	95% 신뢰구간	n
검증 통과	100.0%	±0.0%	80
첫 응답 통과	100.0%	±0.0%	80
인용 정밀도	100.0%	±0.0%	80
핵심 근거	100.0%	±0.0%	80
CLI 유효	100.0%	±0.0%	80
조치 작업	99.4%	±1.2%	80
대상 일치	100.0%	±0.0%	52
노출 없음	100.0%	±0.0%	80
지어냄 없음	100.0%	±0.0%	80
문체 준수	100.0%	±0.0%	80

항목	값
비용 합계	$4.98 (시도당 평균 $0.062)
지연 (중앙값 / 최대)	24.0초 / 31.9초
재시도한 시도	0건

만점이 아닌 지표:

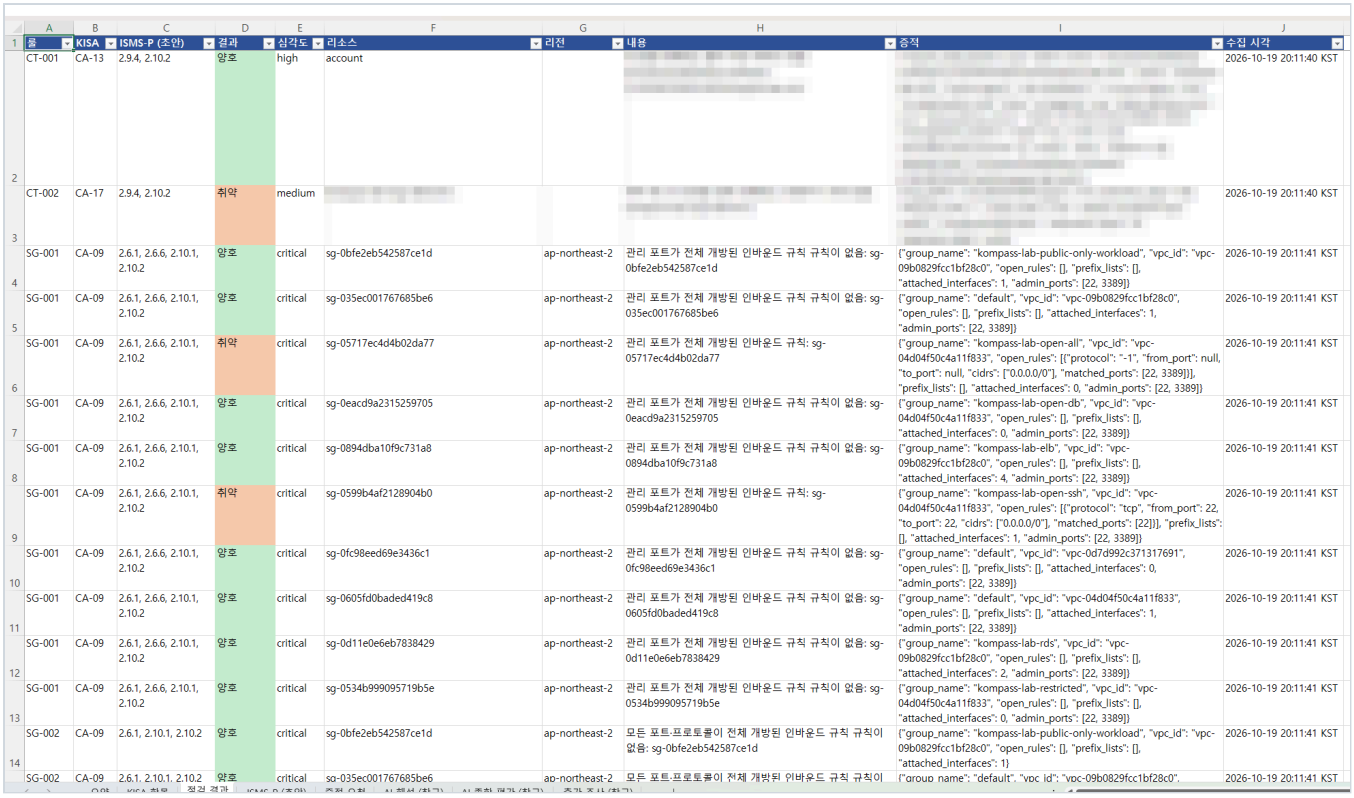
- syn-sg-001-region-error #0: 조치 작업

해설 평가셋 기준선: 40개 케이스 × 2회, 10개 지표와 비용·지연

결과물

실습 계정(취약·양호 리소스를 함께 배포한 별도 AWS 계정)을 점검한 실제 출력임. 계정 ID·버킷 이름 접미사·출발지 IP는 가렸고, 보안그룹 등 실습 리소스 ID는 일회용이라 그대로 둠.

점검표: 룰별 판정에 KISA 항목·ISMS-P 통제항목, 대상 리소스, 판정 근거가 된 원본 설정(증적)을 붙임. Markdown·Excel·JSON으로 출력함.



	A	B	C	D	E	F	G	H	I	J
1	룰	KISA	ISMS-P (초안)	결과	심각도	리소스	리전	내용	증적	수집 시각
2	CT-001	CA-13	2.9.4, 2.10.2	양호	high	account				2026-10-19 20:11:40 KST
3	CT-002	CA-17	2.9.4, 2.10.2	취약	medium					2026-10-19 20:11:40 KST
4	SG-001	CA-09	2.6.1, 2.6.6, 2.10.1, 2.10.2	양호	critical	sg-0bfe2eb542587ce1d	ap-northeast-2	관리 포트가 전체 개방된 인바운드 규칙 규칙이 없음: sg-0bfe2eb542587ce1d	{"group_name": "kompass-lab-public-only-workload", "vpc_id": "vpc-09b0829fcc1bf28c0", "open_rules": [], "prefix_lists": [], "attached_interfaces": 1, "admin_ports": [22, 3389]}	2026-10-19 20:11:41 KST
5	SG-001	CA-09	2.6.1, 2.6.6, 2.10.1, 2.10.2	양호	critical	sg-035ec001767685be6	ap-northeast-2	관리 포트가 전체 개방된 인바운드 규칙 규칙이 없음: sg-035ec001767685be6	{"group_name": "default", "vpc_id": "vpc-09b0829fcc1bf28c0", "open_rules": [], "prefix_lists": [], "attached_interfaces": 1, "admin_ports": [22, 3389]}	2026-10-19 20:11:41 KST
6	SG-001	CA-09	2.6.1, 2.6.6, 2.10.1, 2.10.2	취약	critical	sg-05717ec4d4b02da77	ap-northeast-2	관리 포트가 전체 개방된 인바운드 규칙: sg-05717ec4d4b02da77	{"group_name": "kompass-lab-open-all", "vpc_id": "vpc-04d04f50c4a11f833", "open_rules": [{"protocol": "-1", "from_port": null, "to_port": null, "cidrs": ["0.0.0.0/0"], "matched_ports": [22, 3389]}], "prefix_lists": [], "attached_interfaces": 0, "admin_ports": [22, 3389]}	2026-10-19 20:11:41 KST
7	SG-001	CA-09	2.6.1, 2.6.6, 2.10.1, 2.10.2	양호	critical	sg-0eacd9a2315259705	ap-northeast-2	관리 포트가 전체 개방된 인바운드 규칙 규칙이 없음: sg-0eacd9a2315259705	{"group_name": "kompass-lab-open-db", "vpc_id": "vpc-04d04f50c4a11f833", "open_rules": [], "prefix_lists": [], "attached_interfaces": 0, "admin_ports": [22, 3389]}	2026-10-19 20:11:41 KST
8	SG-001	CA-09	2.6.1, 2.6.6, 2.10.1, 2.10.2	양호	critical	sg-0894dba10f9c731a8	ap-northeast-2	관리 포트가 전체 개방된 인바운드 규칙 규칙이 없음: sg-0894dba10f9c731a8	{"group_name": "kompass-lab-elb", "vpc_id": "vpc-09b0829fcc1bf28c0", "open_rules": [], "prefix_lists": [], "attached_interfaces": 4, "admin_ports": [22, 3389]}	2026-10-19 20:11:41 KST
9	SG-001	CA-09	2.6.1, 2.6.6, 2.10.1, 2.10.2	취약	critical	sg-0599b4af2128904b0	ap-northeast-2	관리 포트가 전체 개방된 인바운드 규칙: sg-0599b4af2128904b0	{"group_name": "kompass-lab-open-ssh", "vpc_id": "vpc-04d04f50c4a11f833", "open_rules": [{"protocol": "tcp", "from_port": 22, "to_port": 22, "cidrs": ["0.0.0.0/0"], "matched_ports": [22]}], "prefix_lists": [], "attached_interfaces": 1, "admin_ports": [22, 3389]}	2026-10-19 20:11:41 KST
10	SG-001	CA-09	2.6.1, 2.6.6, 2.10.1, 2.10.2	양호	critical	sg-0fc98eed69e3436c1	ap-northeast-2	관리 포트가 전체 개방된 인바운드 규칙 규칙이 없음: sg-0fc98eed69e3436c1	{"group_name": "default", "vpc_id": "vpc-0d7d992c371317691", "open_rules": [], "prefix_lists": [], "attached_interfaces": 0, "admin_ports": [22, 3389]}	2026-10-19 20:11:41 KST
11	SG-001	CA-09	2.6.1, 2.6.6, 2.10.1, 2.10.2	양호	critical	sg-0605fd0baded419c8	ap-northeast-2	관리 포트가 전체 개방된 인바운드 규칙 규칙이 없음: sg-0605fd0baded419c8	{"group_name": "default", "vpc_id": "vpc-04d04f50c4a11f833", "open_rules": [], "prefix_lists": [], "attached_interfaces": 1, "admin_ports": [22, 3389]}	2026-10-19 20:11:41 KST
12	SG-001	CA-09	2.6.1, 2.6.6, 2.10.1, 2.10.2	양호	critical	sg-0d11e0e6eb7838429	ap-northeast-2	관리 포트가 전체 개방된 인바운드 규칙 규칙이 없음: sg-0d11e0e6eb7838429	{"group_name": "kompass-lab-rds", "vpc_id": "vpc-09b0829fcc1bf28c0", "open_rules": [], "prefix_lists": [], "attached_interfaces": 2, "admin_ports": [22, 3389]}	2026-10-19 20:11:41 KST
13	SG-001	CA-09	2.6.1, 2.6.6, 2.10.1, 2.10.2	양호	critical	sg-0534b999095719b5e	ap-northeast-2	관리 포트가 전체 개방된 인바운드 규칙 규칙이 없음: sg-0534b999095719b5e	{"group_name": "kompass-lab-restricted", "vpc_id": "vpc-04d04f50c4a11f833", "open_rules": [], "prefix_lists": [], "attached_interfaces": 0, "admin_ports": [22, 3389]}	2026-10-19 20:11:41 KST
14	SG-002	CA-09	2.6.1, 2.10.1, 2.10.2	양호	critical	sg-0bfe2eb542587ce1d	ap-northeast-2	모든 포트·프로토콜이 전체 개방된 인바운드 규칙 규칙이 없음: sg-0bfe2eb542587ce1d	{"group_name": "kompass-lab-public-only-workload", "vpc_id": "vpc-09b0829fcc1bf28c0", "open_rules": [], "prefix_lists": [], "attached_interfaces": 1}	2026-10-19 20:11:41 KST
	SG-002	CA-09	2.6.1, 2.10.1, 2.10.2	양호	critical	sg-035ec001767685be6	ap-northeast-2	모든 포트·프로토콜이 전체 개방된 인바운드 규칙 규칙이	{"group_name": "default", "vpc_id": "vpc-09b0829fcc1bf28c0",	2026-10-19 20:11:41 KST

LLM 해설: SG-001(관리 포트 전체 개방)에 대한 원문 인용, 위험, 조치 절차, AWS CLI 명령. 인용은 원문 대조를 통과해 "원문 인용 검증됨"으로 표시됨.

SG-001 관리 포트 전체 개방 — 우선순위 긴급 · 원문 인용 검증됨

대상 finding 2건, 모델 claude-opus-5-5

- 요약:
  - 서울 리전(ap-northeast-2) vpc-04d04f50c4a11f833 내 보안그룹 2개에서 관리 포트(22/SSH, 3389/RDP)가 0.0.0.0/0으로 전체 개방됨
  - sg-05717ec4d4b02da77: 모든 프로토콜·모든 포트(protocol -1)가 인터넷 전체에 허용되어 22·3389 모두 노출됨, 현재 연결된 네트워크 인터페이스는 없음
  - sg-0599b4af2128904b0: TCP 22(SSH)가 인터넷 전체에 허용됨, 네트워크 인터페이스 1개에 연결되어 실제 노출 중임
- 위험:
  - 인터넷 전역에서 SSH 접속 시도가 가능하여 무차별 대입 공격 및 자격증명 탈취 시 서버 장악 위험이 있음
  - 연결된 인스턴스의 SSH 서비스에 취약점이 있을 경우 원격 침해로 이어질 수 있음
  - sg-05717ec4d4b02da77은 현재 미사용이나 향후 인스턴스에 연결되는 즉시 모든 포트가 인터넷에 노출되는 잠재 위험이 있음
  - 침해 서버를 거점으로 VPC 내부로 횡적 이동 및 내부 정보 유출 위험이 있음
- 우선순위 근거: sg-0599b4af2128904b0가 실제 인터페이스에 연결된 채 SSH를 인터넷 전체에 노출하고 있어 즉시 조치 필요함.

근거 인용:

- KISA CA-09: "관리자 IP 또는 특정 IP 및 계정에서만 접속할 수 있도록 설정"
- KISA CA-09: "불필요한 방화벽 규칙(또는 보안그룹 규칙)이 존재하는지 주기적으로 확인"
- KISA CA-09: "취약 : 접근 제어 정책을 비주기적으로 검토하고 불필요한 규칙이 존재하는 경우"
- ISMS-P 2.6.1: "업무목적 및 중요도에 따라 네트워크 분리(DMZ, 서버팜, DB존, 개발존 등)와 접근통제를 적용하여야 한다"
- ISMS-P 2.10.2: "비인가 접근, 설정 오류 등에 따라 중요정보와 개인정보가 유 · 노출되지 않도록"
- ISMS-P 2.6.6: "접근 허용범위 및 기간 설정, 강화된 인증, 구간 암호화"

조치 절차:

1. sg-0599b4af2128904b0에 연결된 인스턴스와 실제 SSH 접속 주체(운영자, 배포 도구 등) 확인
2. 관리자 접속용 고정 IP 대역(사내망, VPN, 배스천 호스트) 확정
3. sg-0599b4af2128904b0에 관리자 IP 대역만 허용하는 TCP 22 규칙 먼저 추가 후 0.0.0.0/0 규칙 삭제(순서 반대로 하면 운영 접속 단절 위험이 있음)
4. 가능하면 SSH 개방 대신 SSM Session Manager 사용으로 인바운드 22 포트 자체 제거 검토
5. sg-05717ec4d4b02da77의 0.0.0.0/0 전체 프로토콜 규칙 삭제, 필요한 서비스 포트만 최소 범위로 재정의
6. sg-05717ec4d4b02da77은 연결된 인터페이스가 없으므로 용도 확인 후 불필요 시 보안그룹 삭제 검토(삭제는 되돌릴 수 없으며 다른 보안그룹의 참조 규칙, 시작 템플릿, IaC 코드에서 참조 여부 사전 확인 필요)
7. 보안그룹 규칙 주기적 검토 절차 수립 및 AWS Config 등으로 0.0.0.0/0 관리 포트 개방 탐지 설정

AWS CLI (실행 전 검토):

```
aws ec2 describe-network-interfaces --region ap-northeast-2 --filters Name=group-id,Values=sg-0599b4af2128904b0
aws ec2 authorize-security-group-ingress --region ap-northeast-2 --group-id sg-0599b4af2128904b0 --protocol tcp --port 22 --cidr <관리자_IP>/32
aws ec2 revoke-security-group-ingress --region ap-northeast-2 --group-id sg-0599b4af2128904b0 --protocol tcp --port 22 --cidr 0.0.0.0/0
aws ec2 revoke-security-group-ingress --region ap-northeast-2 --group-id sg-05717ec4d4b02da77 --ip-permissions 'IpProtocol=-1,IpRanges=[{CidrIp=0.0.0.0/0}]'
aws ec2 delete-security-group --region ap-northeast-2 --group-id sg-05717ec4d4b02da77
```

에이전트 추가 조사: 같은 SG-001에 대해 에이전트가 네트워크 인터페이스·서브넷 라우팅·CloudTrail 이력을 직접 조회함(도구 호출 8회). 해설은 판정 결과만 보고 SSH가 "실제 노출 중"이라고 썼으나, 조사는 연결된 인터페이스

에 공인 IP와 인터넷 게이트웨이 경로가 없어 현재 외부 접근 경로가 확인되지 않음을 밝힘. 판정(취약)은 그대로 두고 사실마다 근거 호출(T1~T8)을 달아 사람이 판단할 근거만 보강함.

SG-001 관리 포트 전체 개방 — 근거 검증됨

대상 finding 2건, 도구 호출 8회, 모델 claude-opus-5-5, 종료 end_turn

- 요약:
  - sg-05717ec4d4b02da77: 모든 프로토콜·포트를 0.0.0.0/0에 여는 인바운드 규칙 확인. 연결된 네트워크 인터페이스는 없음
  - sg-0599b4af2128904b0: TCP 22를 0.0.0.0/0에 여는 인바운드 규칙 확인. 연결 대상은 인스턴스에 붙지 않은 ENI 1개(eni-005836142f983e8d0, 상태 available). 이 ENI는 공인 IP가 없음
  - eni-005836142f983e8d0이 속한 서브넷 subnet-0ac648ea4b609f8c9의 라우팅 테이블에는 local 경로만 있음. 인터넷 게이트웨이 경로는 없음
  - 두 보안그룹 모두 2026-10-19 18:42경 kompass-lab-admin 사용자가 수 초 사이에 만듦. 생성 직후 기본 아웃바운드 규칙을 지우고 인바운드 규칙을 추가함
  - 따라서 지금 인터넷에서 실제로 들어올 수 있는 경로는 확인되지 않음. 다만 앞으로 인스턴스나 공인 IP가 붙으면 바로 노출되는 구성임

확인된 사실:

- sg-05717ec4d4b02da77(이름 kompass-lab-open-all, VPC vpc-04d04f50c4a11f833)의 인바운드 규칙이 0.0.0.0/0에 모든 프로토콜(-1)·모든 포트를 허용함. 아웃바운드 규칙은 없음 (근거: T3)
- sg-05717ec4d4b02da77에 연결된 네트워크 인터페이스가 없음 (근거: T2)
- sg-0599b4af2128904b0(이름 kompass-lab-open-ssh, VPC vpc-04d04f50c4a11f833)의 인바운드 규칙이 0.0.0.0/0에 TCP 22만 허용함. 아웃바운드 규칙은 없음 (근거: T4)
- sg-0599b4af2128904b0는 ENI eni-005836142f983e8d0(설명 kompass lab: workload in private subnet, 서브넷 subnet-0ac648ea4b609f8c9) 1개에 연결됨. 이 ENI는 상태 available, instance_id 없음, 공인 IP 없음, requester_managed false임 (근거: T1)
- subnet-0ac648ea4b609f8c9은 명시적 연결 없이 라우팅 테이블 rtb-07464c4b47fbb5b11을 따름. 경로는 10.10.0.0/16 → local 하나뿐이고 인터넷 게이트웨이 경로가 없음(public_via_internet_gateway false) (근거: T5)
- sg-05717ec4d4b02da77 이력: 2026-10-19T18:42:23 CreateSecurityGroup → 18:42:24 RevokeSecurityGroupEgress(1건은 성공, 1건은 Client.InvalidPermission.NotFound 오류) → 18:42:26 AuthorizeSecurityGroupIngress 순서임. 모두 kompass-lab-admin 사용자가 [redacted]서 호출함 (근거: T6)
- sg-0599b4af2128904b0 이력: 2026-10-19T18:42:24 CreateSecurityGroup → 18:42:25 RevokeSecurityGroupEgress(성공 1건, NotFound 오류 1건) → 18:42:26 CreateNetworkInterface(eni-005836142f983e8d0) 및 AuthorizeSecurityGroupIngress 순서임. 모두 kompass-lab-admin 사용자가 [redacted]서 호출함 (근거: T7)
- eni-005836142f983e8d0 생성(CreateNetworkInterface) 이벤트의 리소스 목록에 sg-0599b4af2128904b0와 함께 sg-0605fd0baded419c8(default 보안그룹)이 나타남. sg-0605fd0baded419c8은 자기 자신 그룹에서 오는 인바운드만 허용하고 아웃바운드는 0.0.0.0/0 전체를 허용함 (근거: T7, T8)

사람이 확인할 질문:

- kompass-lab-admin 사용자가 2026-10-19 18:42경 sg-05717ec4d4b02da77, sg-0599b4af2128904b0, eni-005836142f983e8d0을 연달아 만든 목적 확인 필요(점검 테스트·IaC 자동화인지, 실제 운영용인지)
- eni-005836142f983e8d0이 앞으로 인스턴스에 붙거나 EIP를 받을 계획이 있는지 확인 필요
- subnet-0ac648ea4b609f8c9의 라우팅 테이블 rtb-07464c4b47fbb5b11이 나중에 인터넷 게이트웨이 경로를 갖게 될 가능성 확인 필요(이번 조사에서는 VPN·피어링 등 IGW 외 경로를 별도로 조사하지 않았으며, 조회 결과에는 local 경로만 있었음)
- sg-05717ec4d4b02da77, sg-0599b4af2128904b0를 삭제하거나 출처 CIDR을 제한할 수 있는지 담당자 확인 필요

finding별 메모:

- `SG-001:ap-northeast-2:sg-05717ec4d4b02da77` : - 모든 프로토콜·포트가 0.0.0.0/0에 열린 규칙이어서 22, 3389가 포함됨 - 연결된 인터페이스가 없어 지금 노출되는 자원은 확인되지 않음 - 2026-10-19에 kompass-lab-admin이 만들고 곧바로 규칙을 설정한, 쓰이지 않는 그룹임 - 생성 목적(테스트·자동화 여부)과 삭제 가능 여부 확인 필요
- `SG-001:ap-northeast-2:sg-0599b4af2128904b0` : - TCP 22가 0.0.0.0/0에 열림 - 연결된 eni-005836142f983e8d0은 인스턴스에 붙지 않았고(available) 공인 IP도 없음 - 서브넷 subnet-0ac648ea4b609f8c9에 인터넷 게이트웨이 경로가 없어 지금 인터넷에서 들어올 경로는 확인되지 않음 - 인스턴스 연결, EIP 연결, 라우팅 변경 중 하나라도 생기면 노출될 수 있음 - 인바운드 출처 CIDR을 좁히거나 그룹을 정리할지 검토 필요

도구 호출:

호출	도구	입력	결과
T1	ec2_interfaces_for_security_group	{"group_id": "sg-0599b4af2128904b0", "region": "ap-northeast-2"}	정상
T2	ec2_interfaces_for_security_group	{"group_id": "sg-05717ec4d4b02da77", "region": "ap-northeast-2"}	정상
T3	ec2_security_group	{"group_id": "sg-05717ec4d4b02da77", "region": "ap-northeast-2"}	정상
T4	ec2_security_group	{"group_id": "sg-0599b4af2128904b0", "region": "ap-northeast-2"}	정상
T5	ec2_subnet_routes	{"subnet_id": "subnet-0ac648ea4b609f8c9", "region": "ap-northeast-2"}	정상
T6	cloudtrail_lookup_events	{"attribute_key": "ResourceName", "attribute_value": "sg-05717ec4d4b02da77", "region": "ap-northeast-2"}	정상
T7	cloudtrail_lookup_events	{"attribute_key": "ResourceName", "attribute_value": "sg-0599b4af2128904b0", "region": "ap-northeast-2"}	정상
T8	ec2_security_group	{"group_id": "sg-0605fd0baded419c8", "region": "ap-northeast-2"}	정상

기술적 도전

1. 마스킹 누락으로 식별자가 LLM에 전송된 사고

첫 두 차례의 실제 해설 실행 뒤 프롬프트를 로컬에서 재구성해 검사하다 실습 계정의 S3 버킷 이름 4개와 서브넷 ID 1개가 가려지지 않고 전송된 것을 발견함. 원인은 이름 수집 범위 누락, dict 키 미마스킹, 치환 순서 문제였고, 테스트 데이터가 실제 증적 형태와 달라 드러나지 않았음. 전송 직전 검사(fail closed)와 실제 증적 형태의 회귀 테스트, 평가 지표 "식별정보 노출 없음"을 더함. 같은 실습 결과의 재검사와 이후 모든 평가 실행에서 노출 0건.

2. 마스킹과 출력 품질의 상충

식별정보를 가리면 안전하지만, 이름 자체가 의미를 가진 AWS 고정 값까지 가리면 LLM이 판단 근거를 잃음. AWS가 수정을 막아 둔 기본 파라미터 그룹(`default.mysql8.0`)이 가려지자 모델이 그 그룹을 고치는 명령을 냈

고(대상 일치 91.7%), 조사에서는 루트 사용자 `root`가 가려져 "실제 루트인지 확인 필요"라는 불필요한 질문이 생김. "모든 AWS 계정에 똑같이 있는 값이면 고객을 식별하지 못함"을 기준으로 `root`와 ELB ARN의 종류 값(`app`·`net`)만 마스킹에서 제외하고, "식별정보 노출 없음"과 "대상 일치" 지표를 함께 보며 조정함. 기본 파라미터 그룹 이름의 제외는 남은 과제로 둠.

3. 확인하지 못한 대상이 "대상 없음"으로 보고된 결함

AWS 자격증명 보고서가 4시간 안의 보고서를 재사용해, 실습 재배포 직후 만든 MFA 미설정 사용자가 빠지고 룰이 "해당 사용자 없음"으로 보고함. 보고서에 없는 사용자마다 ERROR를 내고 생성 시각을 증적으로 남겨, 데이터가 없다는 것을 양호로 보고하지 않도록 고침.

클라우드 보안 관점

- **읽기 전용 이중 보장**: 점검 자격증명에는 `SecurityAudit`만 부여하고, 코드에서도 AWS API 호출 직전에 끼어드는 검사로 조회 API(`Describe*`·`Get*`·`List*`, 자격증명 보고서 생성) 외 호출을 차단함. 예외 3개는 작업 이름 단위로만 허용하고 ADR로 기록함.
- **확인하지 못한 것은 양호가 아님**: 권한 오류·수집 실패는 `ERROR`, 사람의 판단이 필요한 경우는 `REVIEW`로 구분함.
- **근거 있는 매핑**: KISA·ISMS-P 매핑은 원문 구절과 대조한 뒤에만 확정하고 근거 수준(직접·해석)을 기록함.
- **실습 환경**: 별도 AWS 계정에 Terraform으로 취약·양호 리소스를 배포하고, 기대 결과표와 실제 판정을 대조하는 통합 테스트를 둠.

개발 방식

- 수집·판정 → 매핑·보고서 → LLM 해석 → 에이전트화 → 확장 순의 단계별 계획으로 진행하고, 설계 결정은 ADR로 남김.
- 룰마다 양호·취약·권한 오류 테스트를 먼저 작성하고, 단위마다 ruff, mypy strict, pytest를 통과시킨 뒤 다음 단위로 넘어감.
- 구현은 Claude Code와 함께 진행함. 기준 원문 대조와 매핑 확정, 실습 환경 배포, 평가 케이스·채점 결과 승인, 읽기 전용 허용 목록 변경은 직접 판단함.

한계와 다음 단계

- **평가**: 어려운 케이스(다중 리전 권한 오류, 정책 해석이 필요한 IAM)와 LLM 판정자 지표 보강 필요. 종합 위험 평가는 아직 평가셋이 없음.
- **LLM**: LLM을 바꿔 끼울 수 있는 구조는 있으나, 현재 연결된 것은 Claude API뿐임. 외부 AI API를 쓸 수 없는 폐쇄망 환경을 위해 사내 서버의 로컬 LLM 연결과 품질 검증이 필요함.
- **범위**: ISMS-P 매핑은 인증 담당자 검토 전 초안임. Azure와 다른 기준(CSAP 등)은 미지원.

링크

- 저장소: https://github.com/zelopy/kompass-isms
- 사용법: README.md
- 설계: ARCHITECTURE.md, 결정 기록 DECISIONS.md, 룰 목록 RULES.md
- 평가셋: evals/README.md